

Gruppenaufgabe 3

Grundlagen der Datenklassifizierung

Szenario

Die «SwissLegal AG», eine mittelgrosse Anwaltskanzlei mit 45 Mitarbeitenden in Bern, hat bisher keine systematische Datenklassifizierung. Mandantendaten, interne Verwaltungsdokumente, Marketingmaterialien und Finanzdaten werden alle gleich behandelt – dieselbe Backup-Frequenz, derselbe Zugriffsschutz. Der neue IT-Leiter hat den Auftrag, ein Datenklassifizierungsschema einzuführen. Als externe Beratungsgruppe unterstützen Sie ihn bei der Entwicklung des Schemas.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Ein mehrstufiges Datenklassifizierungsschema mit definierten Schutzstufen für ein Unternehmen entwickeln und begründen.
- Verschiedene Datenarten eines Unternehmens den korrekten Klassifizierungsstufen zuordnen und die Zuordnung argumentieren.
- Rollen und Verantwortlichkeiten für die Datenklassifizierung in einer Organisation definieren und strukturieren.

Arbeitsauftrag

Erarbeiten Sie in Ihrer Kleingruppe ein vollständiges Datenklassifizierungsschema für die «SwissLegal AG». Definieren Sie mindestens vier Klassifizierungsstufen mit jeweiligen Schutzmassnahmen, ordnen Sie die typischen Datenarten der Kanzlei den Stufen zu, und definieren Sie die Rollen und Verantwortlichkeiten für die Umsetzung.

Ergebnis

Erstellen Sie ein Handout (1–2 Seiten), das das Klassifizierungsschema, die Zuordnung der Datenarten und das Rollenmodell übersichtlich darstellt und dem IT-Leiter als Umsetzungsgrundlage dient.

Musterlösung A | Gruppenaufgabe 3 | Grundlagen der Datenklassifizierung

Ansatz: Strukturiert-analytisch

1. Ausgangslage und Zielsetzung

Die SwissLegal AG behandelt aktuell alle Daten gleich – ein Zustand, der weder kosteneffizient noch sicherheitskonform ist. Mandantendaten unterliegen dem Anwaltsgeheimnis und erfordern höchsten Schutz, während Marketingbroschüren öffentlich zugänglich sein dürfen. Ohne Differenzierung wird entweder zu viel Geld für den Schutz unkritischer Daten ausgegeben oder – gefährlicher – sensible Daten unzureichend geschützt.

Ziel ist die Einführung eines vierstufigen Klassifizierungsschemas, das den gesetzlichen Anforderungen (DSG, BGFA, OR) entspricht und praktisch umsetzbar ist.

2. Vierstufiges Klassifizierungsschema

Stufe	Bezeichnung	Definition	Beispiel
K1	Öffentlich	Daten, die frei zugänglich sind und keinen Schutzbedarf haben	Webseiteninhalte, Medienmitteilungen, Stelleninserate
K2	Intern	Daten, die nur für Kanzleimitarbeitende bestimmt sind	Interne Richtlinien, Organigramme, Sitzungsprotokolle
K3	Vertraulich	Daten, die nur für bestimmte Personengruppen zugänglich sein dürfen	Finanzdaten, HR-Daten, Partnerverträge
K4	Streng vertraulich	Daten mit höchstem Schutzbedarf (Anwaltsgeheimnis, besonders schützenswerte Personendaten)	Mandantendossiers, Prozessstrategien, strafrechtliche Akten

3. Schutzmassnahmen pro Stufe

Massnahme	K1 (Öffentlich)	K2 (Intern)	K3 (Vertraulich)	K4 (Streng vertraulich)
-----------	--------------------	-------------	---------------------	-------------------------

Zugangskontrolle	Keine	Firmennetzwerk erforderlich	Rollenbasiert, Need-to-know	Individuell mit Multi-Faktor-Authentifizierung
Verschlüsselung	Keine	Transport (TLS)	Transport + Ruhe (AES-256)	Transport + Ruhe + Dateiebene
Backup-Frequenz	Wöchentlich	Täglich	Täglich, georedundant	Täglich, georedundant + Offline-Kopie
Aufbewahrung	Keine Vorgabe	1 Jahr	10 Jahre (OR)	Gemäss Mandatsdauer + 10 Jahre
Protokollierung	Keine	Basis-Logging	Detailliertes Access-Logging	Lückenloses Audit-Trail
Löschverfahren	Standard-Löschung	Sichere Löschung	Zertifizierte Löschung	Zertifizierte Löschung + Dokumentation

4. Zuordnung der Datenarten

Datenart	Klassifizierung	Begründung
Webseiteninhalte	K1 – Öffentlich	Für die Öffentlichkeit bestimmt, kein Schutzbedarf
Interne Newsletter	K2 – Intern	Nur für Mitarbeitende relevant, kein sensibles Datenmaterial
Organigramme	K2 – Intern	Interne Organisationsinformation, nicht für Externe bestimmt
Finanzbuchhaltung	K3 – Vertraulich	Gesetzliche Aufbewahrungspflicht (OR Art. 958f), Finanzgeheimnisse
Lohndaten der Mitarbeitenden	K3 – Vertraulich	Besonders schützenswerte Personendaten gemäss DSG

Partnerverträge	K3 – Vertraulich	Vertragliche Geheimhaltungspflichten
Mandantendossiers	K4 – Streng vertraulich	Anwaltsgeheimnis (BGFA Art. 13), höchster Schutzbedarf
Prozessstrategien	K4 – Streng vertraulich	Direkte Auswirkung auf Mandatsführung, höchste Vertraulichkeit
Strafrechtliche Akten	K4 – Streng vertraulich	Besonders sensibel, Anwaltsgeheimnis, DSGVO-Spezialschutz

5. Rollen und Verantwortlichkeiten

Rolle	Person/Gremium	Verantwortlichkeit
Klassifizierungsverantwortlicher (strategisch)	Managing Partner	Genehmigung des Klassifizierungsschemas, Bereitstellung der Ressourcen
Dateneigentümer	Jeweiliger Partner/Teamleiter	Klassifizierung der Daten in seinem Verantwortungsbereich, Überprüfung der Zuordnung
IT-Leiter	IT-Leiter	Technische Umsetzung der Schutzmassnahmen, Überwachung, Reporting
Alle Mitarbeitenden	Alle	Einhaltung der Klassifizierungsvorgaben im Arbeitsalltag, Meldung von Verstössen
Revisionsstelle	Externe Revision	Jährliche Überprüfung der Einhaltung des Klassifizierungsschemas

6. Umsetzungsplan

Phase	Inhalt	Zeitraumen
-------	--------	------------

1 – Genehmigung	Vorstellung beim Partnermeeting, Genehmigung des Schemas	Monat 1
2 – Inventar	Erfassung aller Datenbestände und Zuordnung zu den Klassifizierungsstufen	Monat 1–2
3 – Technische Umsetzung	Einrichtung der Zugriffsrechte, Verschlüsselung, Backup-Anpassung	Monat 2–3
4 – Schulung	Schulung aller Mitarbeitenden zum neuen Schema	Monat 3
5 – Go-Live und Kontrolle	Aktivierung, laufende Überwachung, erste Revision nach 6 Monaten	Monat 4+

7. Fazit

Das vorgeschlagene vierstufige Klassifizierungsschema bietet der SwissLegal AG eine klare, praktikable Struktur, die sowohl die gesetzlichen Anforderungen (DSG, BGFA, OR) als auch die betrieblichen Bedürfnisse berücksichtigt. Die Schutzmassnahmen sind proportional zum Schutzbedarf – öffentliche Daten erhalten minimalen Schutz, Mandantendaten maximalen. Die klar definierten Rollen stellen sicher, dass die Klassifizierung nicht nur auf Papier existiert, sondern im Alltag gelebt wird.

Musterlösung B | Gruppenaufgabe 3 | Grundlagen der Datenklassifizierung

Ansatz: Praxisnah-narrativ

1. Der Status quo: Alles gleich behandeln kostet mehr, als man denkt

Wenn man den IT-Leiter der SwissLegal AG fragt, wie die Daten der Kanzlei geschützt sind, antwortet er: «Alles wird täglich gesichert, alles liegt auf demselben Fileserver, und alle Mitarbeitenden haben Zugriff auf alle Ordner.» Klingt erst einmal solide. Ist es aber nicht.

Denn «alles gleich behandeln» bedeutet in der Praxis: Die Marketingbroschüre für die nächste Kanzleiveranstaltung wird genauso aufwendig gesichert wie die Prozessstrategie in einem Millionen-Haftpflichtfall. Gleichzeitig kann die Empfangsmitarbeiterin theoretisch auf die Lohndaten aller Partner zugreifen, weil es keine differenzierten Zugriffsrechte gibt.

Das ist nicht nur ineffizient – es ist gefährlich. Ein Datenleck bei Mandantendaten könnte das Ende der Kanzlei bedeuten. Das Anwaltsgeheimnis ist nicht verhandelbar.

2. Unser Ansatz: Vier Stufen, die jeder versteht

Wir schlagen ein einfaches, vierstufiges Modell vor. Es muss so verständlich sein, dass jede Mitarbeiterin und jeder Mitarbeiter – vom Partner bis zum Praktikanten – sofort versteht, in welche Schublade ein Dokument gehört.

Stufe 1: «Grün» – Öffentlich. Das sind Daten, die jeder sehen darf. Die Kanzleiwebseite, Medienmitteilungen, Stelleninserate. Kein Schutzbedarf, freie Verteilung.

Stufe 2: «Gelb» – Intern. Das sind Daten, die nur innerhalb der Kanzlei geteilt werden sollen. Interne Sitzungsprotokolle, das Organigramm, die Weisung zum Home-Office. Nichts Geheimes, aber auch nicht für die Öffentlichkeit bestimmt. Grundlegender Zugriffsschutz – Zugang nur mit Kanzlei-Login.

Stufe 3: «Orange» – Vertraulich. Hier wird es ernst. Finanzdaten der Kanzlei, Lohnabrechnungen, Partnerverträge, HR-Daten. Diese Daten dürfen nur bestimmte Personen sehen – typischerweise die, die sie für ihre Arbeit brauchen. Zugriffsrechte werden rollenbasiert vergeben. Die Daten werden verschlüsselt gespeichert.

Stufe 4: «Rot» – Streng vertraulich / Anwaltsgeheimnis. Das ist die Königsdisziplin. Mandantendossiers, Prozessstrategien, strafrechtliche Akten, Korrespondenz mit Mandanten. Diese Daten unterliegen dem Anwaltsgeheimnis nach Art. 13 BGFA. Ein Verstoß ist nicht nur eine Unannehmlichkeit – er ist strafbar. Diese Daten erfordern höchsten Schutz: Multi-Faktor-Authentifizierung, Dateiverschlüsselung, lückenloses Zugriffsprotokoll und Offline-Backup.

3. Die Alltagsprobe: Passt das Schema in den Kanzleialltag?

Testen wir das Schema an einem typischen Arbeitstag:

Szenario A: Rechtsanwältin Müller arbeitet an der Prozessstrategie für einen Mandanten im Bereich Wirtschaftsstrafrecht. Sie erstellt ein Word-Dokument. → **Stufe Rot (K4).** Das Dokument wird automatisch auf dem verschlüsselten Mandatsbereich gespeichert. Nur RA Müller und der zuständige Partner haben Zugriff.

Szenario B: Die Sekretariatsmitarbeiterin Keller aktualisiert die interne Telefonliste. → **Stufe Gelb (K2).** Das Dokument liegt im internen Bereich. Alle Mitarbeitenden können es einsehen, aber es ist nicht von aussen zugänglich.

Szenario C: Der Finanzchef Brunner erstellt die Quartalsabrechnung. → **Stufe Orange (K3).** Nur Brunner, die Partner und die externe Revisionsstelle haben Zugriff. Die Datei wird verschlüsselt.

Szenario D: Die Marketingverantwortliche Weber gestaltet einen Flyer für eine Veranstaltung. → **Stufe Grün (K1).** Kein Schutzbedarf. Kann auch extern geteilt werden.

Das Schema funktioniert intuitiv. Die Farben helfen: Jeder Ordner auf dem Fileserver bekommt ein farbiges Label. Jedes Dokument bekommt in der Kopfzeile eine Klassifizierungsstufe. So wird die Klassifizierung im Alltag sichtbar und erlebbar.

4. Wer ist wofür verantwortlich?

Die grösste Gefahr bei einer Datenklassifizierung ist, dass sie eingeführt wird und dann niemand sich darum kümmert. Deshalb brauchen wir klare Rollen:

Der Managing Partner gibt das Schema frei und stellt Budget bereit. Er signalisiert damit: «Das ist nicht optional, das ist Kanzleistandard.»

Die Partner und Teamleiter sind Dateneigentümer. Sie entscheiden, wie die Daten in ihrem Bereich klassifiziert werden. RA Müller weiss besser als der IT-Leiter, welche Mandatsdaten besonders sensibel sind. Deshalb liegt die Klassifizierungsentscheidung bei ihr – nicht bei der IT.

Der IT-Leiter setzt die Technik um: Zugriffsrechte, Verschlüsselung, Backup-Differenzierung, Audit-Logs. Er überwacht die Einhaltung und erstellt vierteljährlich einen Compliance-Bericht.

Alle Mitarbeitenden sind verpflichtet, die Klassifizierung im Alltag einzuhalten. Jedes Dokument, das sie erstellen, muss sie gedanklich einordnen: Grün, Gelb, Orange oder Rot? Die Ersts Schulung dauert 90 Minuten. Danach gibt es jährliche Auffrischungen.

5. Was ändert sich beim Backup?

Bisher werden alle Daten täglich gleich gesichert. Mit der Klassifizierung differenzieren wir:

- **Grün (K1):** Wöchentliches Backup genügt. Diese Daten sind leicht reproduzierbar.
- **Gelb (K2):** Tägliches Backup, wie bisher.
- **Orange (K3):** Tägliches Backup, zusätzlich georedundante Kopie an einem zweiten Standort. Aufbewahrung mindestens 10 Jahre (OR-Aufbewahrungspflicht).
- **Rot (K4):** Tägliches Backup, georedundante Kopie UND wöchentliche Offline-Kopie im Banktresor. Das Anwaltsgeheimnis verlangt, dass diese Daten auch bei einem Totalverlust des Rechenzentrums wiederherstellbar sind.

Diese Differenzierung spart Geld bei K1-Daten (weniger Backup-Volumen) und investiert es dort, wo es am meisten gebraucht wird: bei K4-Mandantendaten.

6. Die Umsetzung: pragmatisch in vier Schritten

Schritt 1 (Woche 1–2): Präsentation des Schemas beim Partnermeeting. Diskussion, Anpassung, Freigabe. Ohne das Commitment der Partner funktioniert nichts.

Schritt 2 (Woche 3–6): Dateninventar erstellen. Jeder Partner klassifiziert zusammen mit seinem Team die bestehenden Datenbestände. Der IT-Leiter unterstützt technisch.

Schritt 3 (Woche 7–10): Technische Umsetzung. Ordnerstruktur anpassen, Zugriffsrechte setzen, Verschlüsselung einrichten, Backup-Pläne differenzieren.

Schritt 4 (Woche 11–12): Mitarbeiterschulung. 90 Minuten pro Gruppe. Danach: Go-Live. Erste Kontrolle nach drei Monaten, erste externe Revision nach sechs Monaten.

7. Schlusswort

Die Datenklassifizierung klingt nach Bürokratie. Aber für eine Anwaltskanzlei ist sie existenziell. Das Anwaltsgeheimnis ist nicht verhandelbar, und das Schweizer Datenschutzgesetz verlangt einen risikobasierten Schutz. Mit dem vorgeschlagenen vierstufigen Schema erhält die SwissLegal AG ein Werkzeug, das einfach genug für den Alltag und robust genug für den Ernstfall ist. Die Investition beträgt schätzungsweise 120 Arbeitsstunden und CHF 15 000 für technische Anpassungen – ein Bruchteil dessen, was ein Datenschutzverstoss kosten würde.